

From Findings to Action

Vulnerability Reporting & Security Communication

Overview & Purpose

This afternoon, you will step into the role of a cybersecurity consultant serving as a Security Operations Center (SOC) analyst who has just completed a vulnerability scan for a fictional organization. Your job isn't just to find problems— it's to communicate them in a way that drives action.

This workshop combines two skill sets from this morning's lessons: building a risk-informed vulnerability report (Lesson 2) and translating findings into audience-appropriate communication (Lesson 1). In the real world, these two skills are inseparable - a perfectly prioritized report that nobody reads accomplishes nothing.

Step 1 — Rank the Findings

Track A (MedTech Solutions): 1 - most urgent, 7 - least urgent

- 1.CVE-2024-1001 Patient Portal Web App - PHI
- 2.CVE-2024-1003 Remote Access VPN Gateway - All staff depend on it
- 3.CVE-2024-1007 Appointment Scheduling API - Integrates with patient portal
- 4.CVE-2024-1004 Employee Payroll System - Financial / PII
- 5.CVE-2024-1002 Internal Analytics Reporting Server - internal only
- 6.CVE-2024-1005 Legacy Fax-to-Email Gateway - scheduled for decommission
- 7.CVE-2024-1006 Guest Wi-Fi Captive Portal - no sensitive data accessible\

Track B (Summit Retail Co.): 1 - most urgent, 7 - least urgent

1. CVE-2024-2003 In Store POS Terminal Firmware - PCI-DSS card present transactions
2. CVE-2024-2001 Online Checkout Service - PCI-DSS scope
3. CVE-2024-2007 Customer Loyalty Mobile App Backend - stores customer PII
4. CVE-2024-2004 Inventory Management API - supply chain data
5. CVE-2024-2005 Marketing Email Platform internal/vendor managed
6. CVE-2024-2002 Corporate Intranet Wiki - internal only
7. CVE-2024-2006 Employee Time-Clock Kiosk - internal only

Step 2 – Write Your Executive Summary

Track A (MedTech Solutions): Executive Statement

-I would like to bring your attention to these critical findings just discovered on our last quarterly vulnerability scan:

- 1. CVE-2024-1001 (Patient Portal Web App)
- 2. CVE-2024-1003 (Remote Access VPN gateway)
- 3. CVE-2024-1007 (Appointment Scheduling API)

-All 3 of these vulnerabilities are deemed urgent due to the likelihood of them being accessed by attackers, and potential impact to the company being immense. And the potential of exposing sensitive PHI data, which would place the company in a precarious position with HIPPA compliance, and erode patient trust.

-I recommend immediate mitigation techniques (mitigation, patching, increased access controls) for IT to implement, and briefing PR, and legal teams (for compliance) of situation to re-assure patients, and employees that although these were found - we are aware, and diligently working to resolve the issues.

Track B (Summit Retail Co.): Executive Statement

-I want to bring to your attention the following critical findings just discovered on our last quarterly vulnerability scan:

- 1. CVE-2024-2003 In Store POS Terminal Firmware
- 2. CVE-2024-2001 Online Checkout Service
- 3. CVE-2024-2007 Customer Loyalty App Backend

- All three of these findings are urgent in nature. There is a very good chance that they could be exploited causing data exposure of PII to include customer card data, which could place our PCI-DSS compliance in jeopardy. Not to mention the erosion of trust from customers if this became a breach, and public knowledge, which could greatly impact business.

-My recommendations are to take immediate action to close vulnerabilities by having IT apply mitigation techniques (where applicable), and patching (if possible). Brief legal team (in case of compliance or legal issues), and PR team (in case of a breach).

Step 3 – Complete the Risk Rating Table

Track A (MedTech Solutions):

CVE ID	Asset/System	CVSS	Exploit Likelihood	Exposure	Business Criticality	Priority Rank
CVE-2024-1001	Patient Portal Web App (portal.medtechsolutions.com)	6.8	High	Public-facing	Critical (PHI)	1st - Business critical, high likelihood of exposure, public-facing, PHI implications.
CVE-2024-1002	Internal Analytics Reporting Server	9.6	Low	Internal only (isolated VLAN)	Medium	5th - Business medium, internal, low likelihood of exposure.
CVE-2024-1003	Remote Access VPN Gateway	8.1	High	Public-facing	Critical (all remote staff depend on it)	2nd - Business critical, public facing, high likelihood of exposure.
CVE-2024-1004	Employee Payroll System	5.4	Medium	Internal only	High (financial/PII data)	4th - Business high, internal only, with medium likelihood of exposure.
CVE-2024-1005	Legacy Fax-to-Email Gateway	7.2	Low	Internal only	Low (scheduled for decommission next quarter)	6th - Business low, internal, low likelihood of exposure, and set to be decommissioned.
CVE-2024-1006	Guest Wi-Fi Captive Portal	4.3	Low	Public-facing	Low (no sensitive data accessible)	7th - Business low, no sensitive data, low likelihood of exposure.
CVE-2024-1007	Appointment Scheduling API	6.1	High	Public-facing	High (integrates directly with patient portal)	3rd - Business high, public facing, with high likelihood of exposure.

Track B (Summit Retail Co.):

CVE ID	Asset/System	CVSS	Exploit Likelihood	Exposure	Business Criticality	Priority Rank
CVE-2024 2001	Online Checkout Service (checkout.summitretail.com)	7.4	High	Public-facing	Critical (PCI-DSS scope, card payments)	2nd - Business critical, PCI-DSS scope, with high likelihood of exposure, and public facing.
CVE-2024 2002	Corporate Intranet Wiki	9.4	Low	Internal only	Low	6th - Business low, internal only, with low likelihood of exposure
CVE-2024 2003	In-Store POS Terminal Firmware	8.3	High	Public-facing (customer facing terminals)	Critical (PCI-DSS, card-present transactions)	1st - Business critical, PCI-DSS, public facing, with high likelihood of exposure.
CVE-2024 2004	Inventory Management API	5.9	Medium	Partner-facing (B2B integration)	High (supply chain data)	4th - Business high, medium likelihood of exposure, but supply chain data.
CVE-2024 2005	Marketing Email Platform (3rd party integration)	6.5	Low	Internal / vendor managed	Medium	5th - Business medium, low likelihood of exposure, internal, vendor managed.
CVE-2024 2006	Employee Time-Clock Kiosk	4.8	Low	Internal only	Low	7th - Business low, internal, low likelihood of exposure.
CVE-2024 2007	Customer Loyalty Mobile App Backend	6.2	High	Public-facing	High (stores customer PII)	3rd - Business high, customer PII, public facing, and high likelihood of

						exposure.
--	--	--	--	--	--	-----------

Step 4 — Detail Affected Assets & Remediation

Track A (MedTech Solutions):

- 1. CVE-2024-1001 (Patient Portal Web App)
 - enable MFA, restrict access, actively monitor
 - Owner: IT dept.

- 2. CVE-2024-1003 (Remote Access VPN gateway)
 - restrict access of VPN to ABAC configurations, enable MFA if not already done
 - Owner: IT dept.

- 3. CVE-2024-1007 (Appointment Scheduling API)
 - restrict access, or shutdown temporarily if necessary to mitigate, and provide a number to call for scheduling. Enforce MFA if not already done.
 - Owner: IT dept./scheduling personnel

Track B (Summit Retail Co.):

- 1. CVE-2024-2003 In Store POS Terminal Firmware
 - Temporarily shutdown POS terminals in stores if no patch is available, ask customers for cash if possible. Ensure encryption of card data in transit, and at rest, actively monitor till resolved.
 - Owner: CISO, executive staff

- 2. CVE-2024-2001 Online Checkout Service
 - Enforce MFA, active monitoring, and data access restrictions (ABAC, RBAC)
 - Owner: IT dept., executive staff

- 3. CVE-2024-2007 Customer Loyalty App Backend
 - If no patch is available, disable temporarily, restrict access
 - Owner: IT dept., CISO

Step 5 — Add Supporting Details

Track A (MedTech Solutions):

- 1. CVE-2024-1001 (Patient Portal Web App)
 - Web app vulnerability scan, reference NIST
- 2. CVE-2024-1003 (Remote Access VPN gateway)
 - Vulnerability scanner such as Nessus/Tenable, Qualys, or OpenVAS, reference is NIST
- 3. CVE-2024-1007 (Appointment Scheduling API)
 - Vulnerability scanner as noted above. Reference is NIST

Track B (Summit Retail Co.):

- 1. CVE-2024-2003 In Store POS Terminal Firmware
 - Authenticated endpoint vulnerability scanning/antivirus/antimalware, reference is NIST NVD, and ESET advisory
- 2. CVE-2024-2001 Online Checkout Service
 - web application vulnerability scanning, reference is NIST NVD
- 3. CVE-2024-2007 Customer Loyalty App Backend
 - authenticated vulnerability scanner or endpoint-management tool to inventory installed Python applications/packages, reference NIST NVD

Step 6 — Build a Visual Aid

Track A (MedTech Solutions):

		Impact		
			CVE-2024-1007 Appointment Scheduling API - Integrates with patient portal	CVE-2024-1001 (Patient Portal Web App)
		CVE-2024-1004 Employee Payroll System - Financial / PII		CVE-2024-1003 Remote Access VPN Gateway - All staff depend on it

		CVE-2024-1002 Internal Analytics Reporting Server - internal only		
Likelihood	CVE-2024-1006 Guest Wi-Fi Captive Portal - no sensitive data accessible	CVE-2024-1005 Legacy Fax-to-Email Gateway - scheduled for decommission		

Track B (Summit Retail Co.):

		Impact		
				CVE-2024-2003 In Store POS Terminal Firmware
		CVE-2024-2004 Inventory Management API - supply chain data	CVE-2024-2007 Customer Loyalty App Backend	CVE-2024-2001 Online Checkout Service
	CVE-2024-1005 Legacy Fax-to-Email Gateway - scheduled for decommission	CVE-2024-2005 Marketing Email Platform internal/vendor managed		
Likelihood	CVE-2024-2006 Employee Time-Clock Kiosk - internal only			

Part 2: Translate Findings into Audience-Specific Communications

Message 1 — Executive / Leadership Briefing (SITREP-style)

Track A (MedTech Solutions):

-During a quarterly scan of network systems, we found multiple vulnerabilities, but want to focus on 3 that are critical to our business, and critical to protecting our patient's PHI. The most critical finding was CVE-2024-1001 (Patient Portal Web App), the next was CVE-2024-1003 (Remote Access VPN gateway), and also CVE-2024-1007 (Appointment Scheduling API). These three vulnerabilities are likely to be breached if not addressed immediately, and the impact to business would be grave, and endanger patient data (PHI), and potential non-compliance with HIPPA.

Track B (Summit Retail Co.):

-During a quarterly scan of network systems, we found multiple vulnerabilities, but want to focus on 3 that are critical, and need immediate attention. CVE-2024-2003 In Store POS Terminal Firmware, CVE-2024-2001 Online Checkout Service, and CVE-2024-2007 Customer Loyalty App Backend. These three vulnerabilities represent a clear and present danger to our business model, and could potentially expose customer PII, and place us at risk of non-compliance with PCI-DSS. We are currently working with IT to address these vulnerabilities, and will continue to give updates as conditions change.

Message 2 — Technical Team Alert

Track A (MedTech Solutions):

-Although there were several vulnerabilities noted in quarterly scan, I would like this team to focus on the most critical: 1. CVE-2024-1001 (Patient Portal Web App), 2. CVE-2024-1003 (Remote Access VPN gateway), 3. CVE-2024-1007 (Appointment Scheduling API), in this order. We need to enable least privilege, RBAC, ABAC, close unnecessary ports, disable unnecessary running programs, and make sure we are up to date on all patches. We will address any other mitigation techniques on a case by case basis. Continue to be diligent, and report any anomalies you may discover. Work with the compliance team in ensuring that we maintain patient PHI, and stay in compliance with HIPPA. Thank you for your hard work.

Track B (Summit Retail Co.):

-There were several vulnerabilities found during the last quarterly scan. The 3 most critical are:

- 1. CVE-2024-2003 In Store POS Terminal Firmware
- 2. CVE-2024-2001 Online Checkout Service
- 3. CVE-2024-2007 Customer Loyalty App Backend

To address these and maintain compliance with PCI-DSS we may need to limit, and control access to terminals, scan services for any malware/viruses, enable MFA, and restrict access to any customer card data. Continue to listen for updates, if we are currently out of compliance, please document why, and document any other anomalies found during scans, or other discovery. Ensure data is encrypted. We want to maintain business operations as normal, but need to ensure customer card data, and PII is protected above all else.

Message 3 — End-User / General Staff Message

Track A (MedTech Solutions):

-During a quarterly scan of systems, we found some vulnerabilities. Three of these are deemed critical. We are diligently working to resolve these issues, and as of yet we have not found any evidence of PHI being exposed, or any sort of breach. Be mindful of cybersecurity, do not click on suspicious links, or attempt to circumvent any policies or procedures that are already in place. We will continue to update on the situation as conditions, and time permit.

Track B (Summit Retail Co.):

-After completing a quarterly scan of systems, we found some vulnerabilities, 3 of which require immediate attention. We are working hard to resolve these issues as we speak. As of yet no breach or exposure of sensitive card data or PHI has been found, but we want to encourage you to be mindful of cybersecurity, and do not click suspicious links, or do anything outside the normal scope of your job. If you run into issues, alert your management. We will continue to update as conditions change, and issues are resolved. Thank you for your time, and attention.